

To learn

- ① Definition
- ② job responsibility
- ③ core skills of security analyst
- ④ value of security

Later in course

- ① Eight security domains
- ② security framework and controls
- ③ common tool and programming language

Introduction to Cybersecurity

Cybersecurity :- the practice of ensuring confidentiality, integrity and availability of information by protecting network, devices, people and data from unauthorized access or criminal exploitation

Threat actor : Any person or group who represent a security risk

Benefits of Security

- ① Protect against External or internal threats
- ② Meets regular compliance
- ③ maintain and improve business productivity
- ④ reduces Expenses
- ⑤ Maintain brand trust

job roles

- ① security analyst or specialist
- ② Cybersecurity analyst or specialist
- ③ security operation Center (SOC) analyst
- ④ information security analyst

Phishing tactic: the psychological tricks designed to (social engineering) manipulate you. They include creating sense of urgency ("Act Now"), creating fear

(Account is locked) or leveraging Authority (impersonating manager)

Phishing indicator: -

These are verifiable signs that message is malicious.

- **Technical indicators:** most definitive flags.
 - incorrect sender email domains
 - malicious link address
- **Content indicators:** less definitive, but Red flag
 - Poor grammar
 - misspelling
 - unusual request
 - generic greeting

*

*

*

Responsibilities of entry-level analyst

- They are responsible for monitoring and protecting information and system

3 primary responsibilities

-> protecting computer and Network systems

↳ first Responder

↳ pen Test

-> prevention software & development.

-> conducting periodic security audit

2 sides of workflow

- Operations :- Responding to detection
and doing investigation

Projects:- Working with other teams to build new
detections or improve the current
detections.

Security analyst
operation

security. engineer
projects operation

Playbook: A list of how to go through a certain detection, and what the analyst needs to look at in order to investigate those incident.



Common Terminology : Cybersecurity

Compliance is the process of adhering to internal standards and external regulation and enables organization to avoid fines and security breaches.

Security framework are guideline used for building plans to help mitigate risk and threat to data and privacy.

Security controls are safeguards designed to reduce specific security risk. They are used with security framework to establish a strong security posture.

Security Posture is an organizations ability to manage its defense of critical assets and data and react to change. A strong security posture leads to lower risk for the organization.

A threat actor, or malicious attacker, in any person or group present a security risk. This risk can relate to computers, application, networks, data

An internal threat can be current or former employee, an external vendor or a trusted partner possesses security risk. At times internal threat is accidental. For Example:-

An employee clicks on a malicious link would be considered an accidental threat. Other times, internal threat actor engages risky activities, such as unauthorized data access

Network security is the practice of keeping an organisation's network infrastructure secure from unauthorized access. This includes data, services, systems and device stored in an organization network

Cloud security is the process of ensuring that assets stored in cloud are properly configured, or set-up correctly, and access to those assets is limited to authorized users. The cloud is a network made up of collection of servers or computer that store resources and data in remote physical location known as data center that can be accessed via internet. Cloud Security is growing subfield in cyber security that specifically focus on the protection of data, infrastructure and applications in cloud.

Programming is a process that can be used to create a specific set of instruction for computer to execute tasks.

task including:

- ① Automation of repetitive task
- ② Reviewing web traffic
- ③ Alerting suspicious activity

Core skills for security

transferable

- Communication
- Collaboration
- Analysis
- Problem Solving

Technical skill

- Programming language
- Security ^{info} and event management
CSIR Tools
(- Alert),
- Computer Forensics

Module 2

Topics

- ① Viruses
- ② Malware
- ③ Social Engineering
- ④ Digital Age
- ⑤ Security domains

Past Attacks

Terms :-

Computer Virus :- A piece of malicious code written to interfere with computer operations and cause damage to data & software

Malware :- software designed to harm devices or networks

1986 Allie brothers created brain virus to track illegal copies of medical software

(intention) [↑] & prevent pirated license
what virus actually did?

attach itself to computer and all the disk computer touched

there forward going global

1988 Robert morres developed program to the size the Internet program crawled the web and installed itself into other computer to tally number of computer that are connected to the internet

What the worm actually did?

failed to keep the tally making itself reinstalling itself until computer ran out of memory and crashed

About 6000 computers were affected, representing 10% of the internet at Time.

Attacks in digital Age

2 Famous Attacks of digital Age

(1) Love letter attack

(2) Equifax Breach

year 2000 on digusman created the love letter malware to steal internet login credentials.

user received email with subject "I Love u" each email had attachment "Love letter for u" when opened malware scanned user address book then automatically send itself to every person on the list & installed program to collect user informed & password. user thought he got it from friend

love letter endpoint affecting 4.5M computers globally. believed to caused 10M in damages.

love letter attack is a good example of social engineering

Social Engineering

A manipulation technique that exploits human error to gain private information, access or valuable

People Prefer

convenience > privacy

Phishing: The use of digital communication to trick people into revealing sensitive data or deploying malicious software.

In 2017 attackers successfully infiltrated credit reporting agency equifax this resulted in one the largest known data breaches of sensitive information

As information of 143 million customer records were stolen and breach affected approx 40% of all Americans

Records included personally identifiable information including social security numbers, D.O.B, drivers license number home address and credit card number

Multiple failiour from Equifax Parts and they settled with U.S. government & paid 575 million \$ to resolve customer complaint and cover fines

Common attacks and their effectiveness

(CSIRTs): Computer security incident response teams

Different attack methods

Phishing is the use of digital communication to trick people into revealing sensitive data or deploying malicious software

→ Types of Phishing.

① Business Email Compromise
(BEC)

- ① A Threat actor sends an email message that seems to be from a known source to make it legitimate request for information in order to obtain financial advantage
- ② spear phishing : A malicious attack targeted towards a specific user. The email again looks to come from legitimate source
- ③ Whaling : A form of spear phishing to target high level executive to gain access to sensitive data
- ④ vishing : The exploit of electronic voice communication to obtain sensitive information or to impersonate a known source
- ⑤ smishing : The use of Text message to trick users, in order to obtain sensitive information or to impersonate known source

→ Malware:-

It is a software designed to harm devices or networks. There are many types of malware. The primary purpose of malware is to obtain money, or in some cases, an intelligent advantage that can be used against a person or an organisation or a territory.

Some of the most common types of malware

→ **Viruses**: malicious code written to interfere with computer operation and cause damage to data and software. A virus needs to be initiated by user (threat actor), who transmits the virus via malicious attachment or download, the virus hides itself in other files in the now infected system. When the infected files are open it allows malicious virus to insert its own code to damage and/or destroy data in system.

→ **Worms**: malware that can duplicate and spread itself across system on its own. In contrast to a virus, a worm does not need to be downloaded by user. Instead, it self-replicates and spreads from an already infected computer to other devices on the same network.

→ **Ransomware**: a malicious attack that locks all the files of infected system to extort money to restore access.

- **Spyware**: malware that used to gather and sell information from infected system without consent. Spyware can be used to access devices. This allows threat actor to collect personal data, such as private email, text and image recordings, and location.

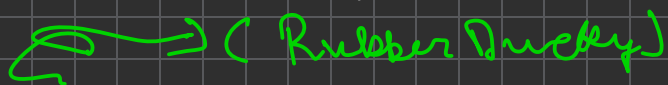
Social Engineering

Social Engineering is a manipulation technique that exploits human error to gain private information, access, or valuable. Human error is usually result of trusting someone without question. It's the mission of threat actor acting as social engineer, to create environment of false trust and lies to exploit as many people as possible.

Types of Social Engineering.

Social media phishing:- A Threat actor collects detailed info about their target from social media sites. Then, they initiate an attack.

Watering hole attack:- A Threat actor attacks the website frequently visited by specific group of user.



USB Baiting: A Threat actor strategically leaves a malware USB stick for employee to find and install to unknowingly infect computer or network.

- **Physical social engineering:** A Threat actor impersonates an employee, customer, or vendor to obtain unauthorized access to physical location.

Social Engineering Principle

Reasons why social engineering are effective include:

① Authority: Threat actor impersonate individual with power.

This is because people, in general, have been conditioned to respect and following figures.

② Intimidation: Threat actors use bullying tactics.

This includes persuading and intimidating victims into doing what they're told.

③ Consensus/Social proof: Because people are comfortable

Because people sometime do thing they believe many other are doing, threat actor use other's trust to pretend they are legitimate. For example: a threat actor might try to gain access to private data by telling an employee that other people at company have given them access to that data in past.

④ Scarcity: A tactic used to imply that good or service are in limited supply.

⑤ Familiarity: Threat actor establish a fake emotional connection with user that can be exploited.

④ Trust:— Threat actors establish an emotional connection with users that can be exploited over time. They use this relationship to develop trust and gain information.

⑤ Urgency: A Threat actor persuades others to respond quickly and without question.

CISSP — (Certified Information Systems Security Professional)
Defined 8 Total Domains
for the Industry

- ① Security and Risk management
- ② Asset security
- ③ Security Architecture & Engineering
- ④ Communication and Network Security
- ⑤ Identity and Access management
- ⑥ Security Assessment and testing
- ⑦ Security operation
- ⑧ Software development security.

① Security and risk management

Defines security goals and objectives, risk mitigation, compliance, Business continuity and the law,

② Asset security

Secures digital & Physical Assets.

also related to the storage, maintenance retention, and destruction of data

③ Security Architecture & Engineering

Optimize data security by ensuring effective tools, system and processes are in place

④ Communication and Network security

manage and secure Physical Networks and wireless communication.

⑤ Identity and Access Management

Keeps data secure, by ensuring user follow established policies to control and manage Physical assets, like office spaces and logical assets like network and application

⑥ Security Assessment and testing

conducting security control testing, collecting and analyzing data, and conducting security Audit to monitor for risk, Threat, and vulnerability

⑦ Security Operation

conducting investigation and implementing preventive measure

⑧ Software development security.

uses secure coding practices, which are a set of recommended guidelines that are used to create secure application and services

Determine the type of Attack.

Attack types

Password attack : an attempt to access password-secured devices, systems, networks, or data. Some forms of password attacks that you'll learn about later in the certificate program are:

- Brute force
- Rainbow table

Password attack falls under the communication and network security domain.

Social engineering attack.

Social engineering is a manipulation technique that exploits human error to gain private information, access, or valuables. Some forms of social engineering attacks that we continue to learn about throughout the program are:

- Phishing
- Smishing
- Vishing
- Spear phishing
- Whaling
- Social media phishing
- Business email compromise (BEC)
- Watering hole attack
- USB (Universal Serial Bus) baiting
- Physical social engineering

Social engineering attacks are related to the security and risk management domain

Physical attack

A physical attack is security incident that affects not only digital but also physical environment where the incident is deployed. some forms of physical attack are:

- Malicious USB cable
- Malicious flash Drive
- Card cloning and skimming

Physical attacks fall under the asset security domain

Adversarial artificial intelligence

Is a technique that manipulate Artificial Intelligence & Machine learning technology to conduct attacks more efficiently. Adversarial Artificial intelligence falls under both the communication and network security and the identity and access management domains.

Supply - Chain attack

A Supply - Chain attack targets systems, applications, hardware, and software to locate a vulnerability where malware can be deployed. Because every item sold undergoes a process that involves third parties, this

means that the security breach can occur at any point in the Supply Chain. These attacks are costly because they can affect multiple organizations and the individuals who work for them. Supply-chain attacks can fall under several domains, including but not limited to the security and risk management, security architecture and engineering, and security operations domains.

Cryptographic attack

A cryptographic attack affects secure forms of communication between a sender and intended recipient. Some forms of cryptographic attacks are:

• Birthday • Collision • Downgrade

Cryptographic attacks fall under the communication and network security domain

Understanding - Attackers

threat actor types

Advanced persistent threat : Advanced persistent threat (APT) have significant expertise accessing an organization's network without authorization.

APTs tend to research their targets (eg, large corporation or government entities) in advance and can remain undetected for an extended period of time. Their intention and motivations can include :

→ Damaging critical infrastructure, such as the power grid and natural resources.

→ Gaining access to intellectual property such as trade secrets or patents.

Insider threat

Insider threat abuse their authorized access to obtain data that may harm an organization.

Their intention and motivation can include :

- Sabotage
- Corruption
- Espionage
- Unauthorized data access or leaks

Hacktivists

hacktivists are threat actor that are driven by a political agenda. They abuse digital technology to accomplish their goal which may include:

- Demonstration
- Propaganda
- Social Change Campaigns
- Fame

hacker types:

A Hacker is any person who uses computer to gain access to computer system, network or data. They can be beginner or advanced technology professional who use their skill for variety of reasons. There are main categories of Hackers:

- **Authorized hacker** are also called **ethical Hackers**: they follow code of ethics and adhere to law to conduct organizational risk evaluation. They are motivated to safeguard people and organization from malicious threat actor

→ **semi authorized hacker** are considered researchers. They search for vulnerabilities but don't take advantage of vulnerability they find.

Unauthorized hackers are also called **unethical hackers**

They are malicious. threat actor who do not follow or respect the law. Their goal is to collect and sell confidential data for financial gain

Terms and definitions from Course 1, Module 2

Adversarial artificial intelligence (AI): A technique that manipulates artificial intelligence (AI) and machine learning (ML) technology to conduct attacks more efficiently

Business Email Compromise (BEC): A type of phishing attack where a threat actor impersonates a known source to obtain financial advantage

CISSP: Certified Information Systems Security Professional is a globally recognized and highly sought-after information security certification, awarded by the International Information Systems Security Certification Consortium

Computer virus: Malicious code written to interfere with computer operations and cause damage to data and software

Cryptographic attack: An attack that affects secure forms of communication between a sender and intended recipient

Hacker: Any person who uses computers to gain access to computer systems, networks, or data

Malware: Software designed to harm devices or networks

Password attack: An attempt to access password secured devices, systems, networks, or data

Phishing: The use of digital communications to trick people into revealing sensitive data or deploying malicious software

Physical attack: A security incident that affects not only digital but also physical environments where the incident is deployed

Physical social engineering: An attack in which a threat actor impersonates an employee, customer, or vendor to obtain unauthorized access to a physical location

Social engineering: A manipulation technique that exploits human error to gain private information, access, or valuables

Social media phishing: A type of attack where a threat actor collects detailed information about their target on social media sites before initiating the attack

Spear phishing: A malicious email attack targeting a specific user or group of users, appearing to originate from a trusted source

Supply-chain attack: An attack that targets systems, applications, hardware, and/or software to locate a vulnerability where malware can be deployed

USB baiting: An attack in which a threat actor strategically leaves a malware USB stick for an employee to find and install to unknowingly infect a network

Virus: refer to “computer virus”

Vishing: The exploitation of electronic voice communication to obtain sensitive information or to impersonate a known source

Watering hole attack: A type of attack when a threat actor compromises a website frequently visited by a specific group of users

Module - 3

• Security frameworks and controls

Security framework are rules & guideline used for building plans to help mitigate risk and threat to data and privacy.

Purpose :-

: Protecting PII (Personally Identifiable Info)

- securing financial information
- Identifying weakness
- Manage Organizational risk
- Aligning security with business goal

Core components :-

- ① Goals
- ② Guideline
- ③ Processes
- ④ Communication

CIA Triad [Confidentiality Integrity Availability]

A foundational model that helps inform how organizations consider risk when setting up systems and security policies

NIST (CSF) Cybersecurity framework

A voluntary framework that consists of standards, guidelines, and best practice to manage risk

Terms and definitions from Course 1, Module 3

Asset: An item perceived as having value to an organization

Availability: The idea that data is accessible to those who are authorized to access it

Compliance: The process of adhering to internal standards and external regulations

Confidentiality: The idea that only authorized users can access specific assets or data

Confidentiality, integrity, availability (CIA) triad: A model that helps inform how organizations consider risk when setting up systems and security policies

Hacktivist: A person who uses hacking to achieve a political goal

Health Insurance Portability and Accountability Act (HIPAA): A U.S. federal law established to protect patients' health information

Integrity: The idea that the data is correct, authentic, and reliable

National Institute of Standards and Technology (NIST) Cyber Security Framework (CSF): A voluntary framework that consists of standards, guidelines, and best practices to manage cybersecurity risk

Privacy protection: The act of safeguarding personal information from unauthorized use

Protected health information (PHI): Information that relates to the past, present, or future physical or mental health or condition of an individual

Security architecture: A type of security design composed of multiple components, such as tools and processes, that are used to protect an organization from risks and external threats

Security controls: Safeguards designed to reduce specific security risks

Security ethics: Guidelines for making appropriate decisions as a security professional

Security frameworks: Guidelines used for building plans to help mitigate risk and threats to data and privacy

Security governance: Practices that help support, define, and direct security efforts of an organization

Sensitive personally identifiable information (SPII): A specific type of PII that falls under stricter handling guidelines

Module - 4

A **SIEM tool** is an application that collects and analyzes log data to monitor critical activities in an organization. A **log** is a record of events that occur within an organization's systems. Depending on the amount of data you're working with, it could take hours or days to filter through log data on your own. SIEM tools reduce the amount of data an analyst must review by providing alerts for specific types of threats, risks, and vulnerabilities.

SIEM tools provide a series of dashboards that visually organize data into categories, allowing users to select the data they wish to analyze. Different SIEM tools have different dashboard types that display the information you have access to.

SIEM tools also come with different hosting options, including on-premise and cloud. Organizations may choose one hosting option over another based on a security team member's expertise. For example, because a cloud-hosted version tends to be easier to set up, use, and maintain than an on-premise version, a less experienced security team may choose this option for their organization.

Network protocol analyzers (packet sniffers)

A **network protocol analyzer**, also known as a **packet sniffer**, is a tool designed to capture and analyze data traffic in a network. This means that the tool keeps a record of all the data that a computer within an organization's network encounters. Later in the program, you'll have an opportunity to practice using some common network protocol analyzer (packet sniffer) tools.

Playbooks

A **playbook** is a manual that provides details about any operational action, such as how to respond to a security incident. Organizations usually have multiple playbooks documenting processes and procedures for their teams to follow. Playbooks vary from one organization to the next, but they all have a similar purpose: To guide analysts through a series of steps to complete specific security-related tasks.

For example, consider the following scenario: You are working as a security analyst for an incident response firm. You are given a case involving a small medical practice that has suffered a security breach. Your job is to help with the forensic investigation and provide evidence to a cybersecurity insurance company. They will then use your investigative findings to determine whether the medical practice will receive their insurance payout.

In this scenario, playbooks would outline the specific actions you need to take to conduct the investigation. Playbooks also help ensure that you are following proper protocols and procedures. When working on a forensic case, there are two playbooks you might follow:

- The first type of playbook you might consult is called the **chain of custody** playbook. Chain of custody is the process of documenting evidence possession and control during an incident lifecycle. As a security analyst involved in a forensic analysis, you will work with the computer data that was breached. You and the forensic team will also need to document who, what, where, and why you have the collected evidence. The evidence is your responsibility while it is in your possession. Evidence must be kept safe and tracked. Every time evidence is moved, it should be reported. This allows all parties involved to know exactly where the evidence is at all times.
- The second playbook your team might use is called the **protecting and preserving evidence** playbook. Protecting and preserving evidence is the process of properly working with fragile and volatile digital evidence. As a security analyst, understanding what fragile and volatile digital evidence is, along with why there is a procedure, is critical. As you follow this playbook, you will consult the **order of volatility**, which is a sequence outlining the order of data that must be preserved from first to last. It prioritizes volatile data, which is data that may be lost if the device in question powers off, regardless of the reason. While conducting an investigation, improper management of digital evidence can compromise and alter that evidence. When evidence is improperly managed during an investigation, it can no longer be used. For this reason, the first priority in any investigation is to properly preserve the data. You can preserve the data by making copies and conducting your investigation using those copies.